Systemsikkerhet

Agenda

- Repetisjon av systemsikkerhet
  - Eksamensspørsmål underveis
- Oblig 4 - Kort gjennomgang av Wireshark
- Eget arbeid



“Kan også kalles endepunktsikkerhet” - Audun Jøsang (tidligere faglærer)

Et system = En datamaskin = et endepunkt

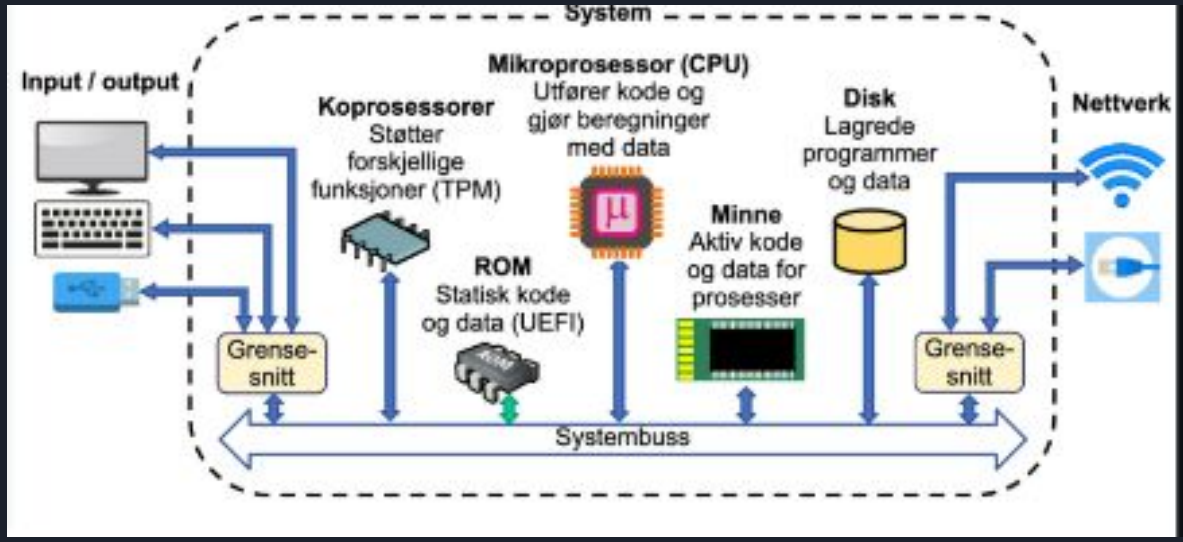
«Å bruke kryptering på internett er som å bruke en pansret bil for å levere kredittkortinformasjon fra en som bor i en pappkartong til en som bor på en parkbenk.»

- Eugene Spafford

Systemarkitektur

Hovedfokus på CPU, TPM, Minne og Disk

- CPU: kjører kode og beregningene
- Minnet holder koden som kjører.
- Disk lagrer data / programmer (langtid)



Systemarkitektur

UEFI: Koden som kjører ved oppstart (boot) av et system ligger i Read Only Memory (ROM)

- Unified Extensible Firmware Interface (UEFI): programvare som starter når du skrur på datamaskinen. Det sjekker maskinvarer og da kjører OS (tidligere BIOS)

TPM - Trusted Platform Module

- Lagrer kryptonøkler og sjekker om systemet ikke har blitt modifisert ved startup (integritet)
  - Eksempler av kryptonøkler kan være passkeys
- Tiltrodd beregning (trusted computing)
  - mer om det senere

Privilegienivåer

Det er ulike privilegienivåer inne i CPU-en

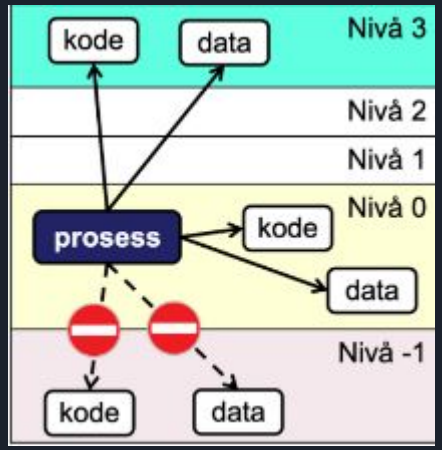
Påvirker hva en *prosess* kan få tilgang til

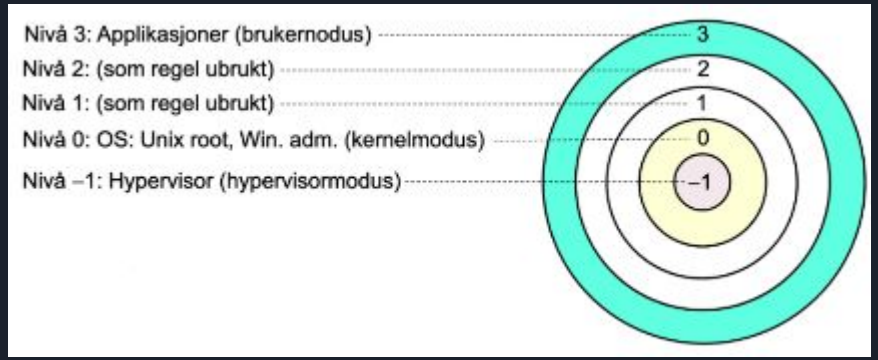
Endre programvare og data på samme eller lavere privilegie nivå.

- *jo lavere jo bedre*

Angriper ønsker da nivå 0 eller -1

Hypervisor (-1) administrer VMs





Intel ME / AMT (nivå -3)

Management Engine

- lite system som kjører separat fra OS og CPU
- Finnes i alle Intel chipper
- Her mer privilegier og har tilgang til praktisk talt alt
  - Kaller det ofte (på kødd) at det er nivå -3 privilegier.
- Setter og klokker og strømstyring og alt før oppstart (UEFI)

AMT - Advanced Management Technology:

- løsning for fjernadministrasjon av arbeidsstasjoner
  - del-funksjon av ME

Eksamen 2024

5 OS privilegienivåer

En prosess kjører i **brukermodus**. Kryss av for hvert privilegienivå om prosessen kan få tilgang til ressurser (f.eks. data og prosess).

Poeng: 1 for hver riktig; -1 for hver feil eller ubesvart; maks 3; minimum 0.

For hvert privilegienivå, indiker om en bruker-prosess kan få tilgang.

	Kan få tilgang	Kan IKKE få tilgang
Nivå -1	○	○
Nivå 0	○	○
Nivå 3	○	○

Maks poeng: 3

5 OS privilegienivåer

En prosess kjører i **brukermodus**. Kryss av for hvert privilegienivå om prosessen kan få tilgang til ressurser (f.eks. data og prosess).

Poeng: 1 for hver riktig; -1 for hver feil eller ubesvart; maks 3; minimum 0.

For hvert privilegienivå, indiker om en bruker-prosess kan få tilgang.

	Kan få tilgang	Kan IKKE få tilgang
Nivå -1	○	○ ✔
Nivå 0	○	○ ✔
Nivå 3	○ ✔	○

Maks poeng: 3

Eksamen 2023

5 OS privilegienivåer

En prosess kjører i **kernelmodus**. Kryss av hvert privilegienivå om prosessen kan få tilgang til ressurser (f.eks. data og prosess).

Poeng: 1 for hver riktig; 0 for hver feil eller ubesvart; maks 3; minimum 0.

For hvert privilegienivå, indiker om en kernel-prosess kan få tilgang.

	Kan IKKE få tilgang	Kan få tilgang
Nivå -1	○	○
Nivå 0	○	○
Nivå 3	○	○

Maks poeng: 3

5 OS privilegienivåer

En prosess kjører i **kernelmodus**. Kryss av hvert privilegienivå om prosessen kan få tilgang til ressurser (f.eks. data og prosess).

Poeng: 1 for hver riktig; 0 for hver feil eller ubesvart; maks 3; minimum 0.

For hvert privilegienivå, indiker om en kernel-prosess kan få tilgang.

	Kan få tilgang	Kan IKKE få tilgang
Nivå 0	✔	
Nivå 3	✔	
Nivå -1		✔

Maks poeng: 3

Virtuelle Maskiner

Fleksibel måte å installere og kjøre systemer på, der programvare etterligner maskinvare

Hypervisoren (nivå -1) er ryggraden til virtuelle maskiner og fungerer som en virtuell CPU

- For VM er Hypervisor = CPU, men er egentlig en mellomleder
- Kan holde styr på flere VMs samtidig
- Hypervisor skal ha høyere privilegium siden den skal styre operativsystemene.
    - VMene tror de er ring 0 (siden de er OS)

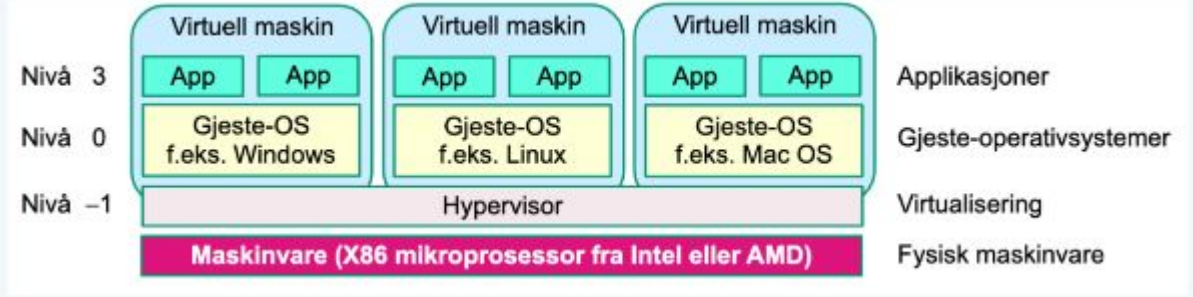
Virtualisering: Type 1

“Native” eller “bare-metal”

Hypervisor ligger i maskinvaren og har høyeste privilegienivå, den kjører på CPU

Fungerer uten verts-OS på maskinen

- F.ex Proxmox : Kernel based VM



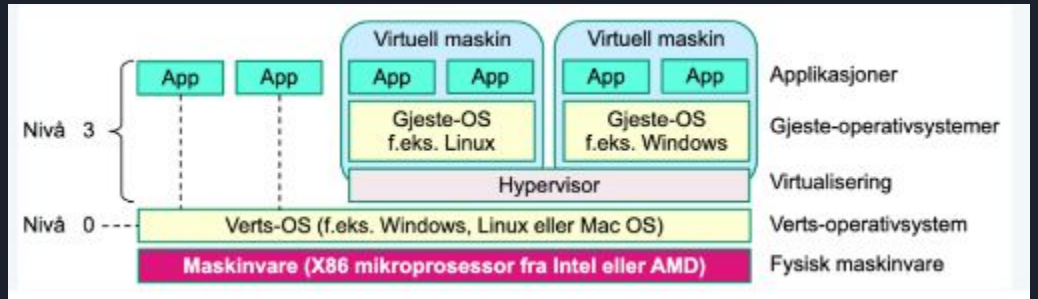
Virtualisering Type 2

Kalles “vertsbasert”

Litt mer typisk. Spesielt hvis dere har brukt VMware workstation

Man laster ned et hypervisor program, eks. VMware, VirtualBox, QEMU som kjører på Verts-OS. Lasted ned som en helt vanlig applikasjon

Verts-OS er på nivå 0, resten er på nivå 3



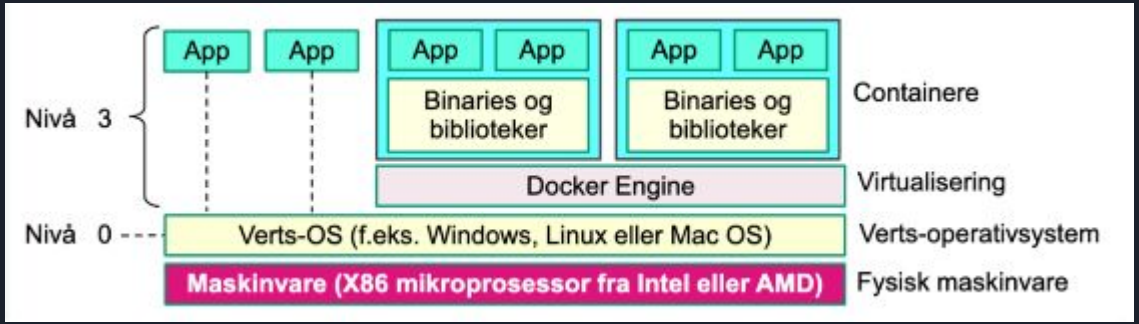
Docker Engine

En variant av type 2 virtualisering.

Brukt i oblig 2

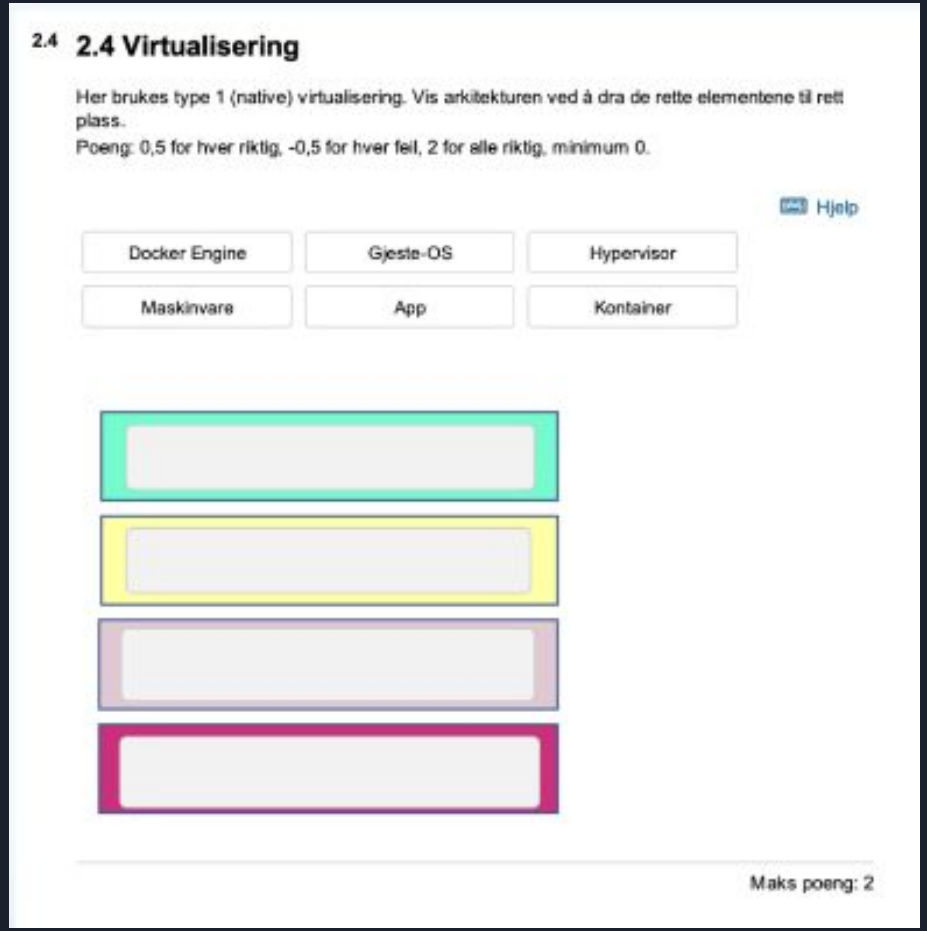
Av og til er det litt mye å bruke et helt OS, eller bare kjøre en applikasjon uavhengig av OS (så den er raskere). Trenger heller ikke et helt gjeste-OS

Så alt av avhengigheter er innebygd i containeren.



Eksamen 2022

1. ?
2. ?
3. ?
4. ?



2.4 2.4 Virtualisering

Her brukes type 1 (native) virtualisering. Vis arkitekturen ved å dra de rette elementene til rett plass.
Poeng: 0,5 for hver riktig, -0,5 for hver feil, 2 for alle riktig, minimum 0.

Hjelp

Kontainer	Hypervisor	Gjeste-OS
Maskinvare	App	Docker Engine



Maks poeng: 2

Eksamen 2022

1. ?
2. ?
3. ?
4. ?

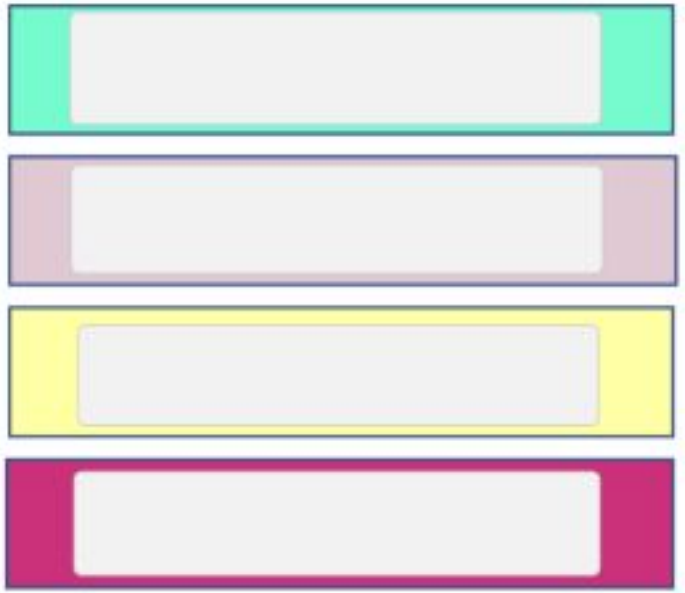
2.5 **2.5 Kontainer**

Her brukes kontainer (Docker Engine). Vis arkitekturen ved å dra de rette elementene til rett plass.

Poeng: 0,5 poeng for hver riktig, -0,5 for hver feil, 2 for alle riktig, minimum 0.

Hjelp

Vert-OS | Docker Engine | Kontainer | Maskinvare



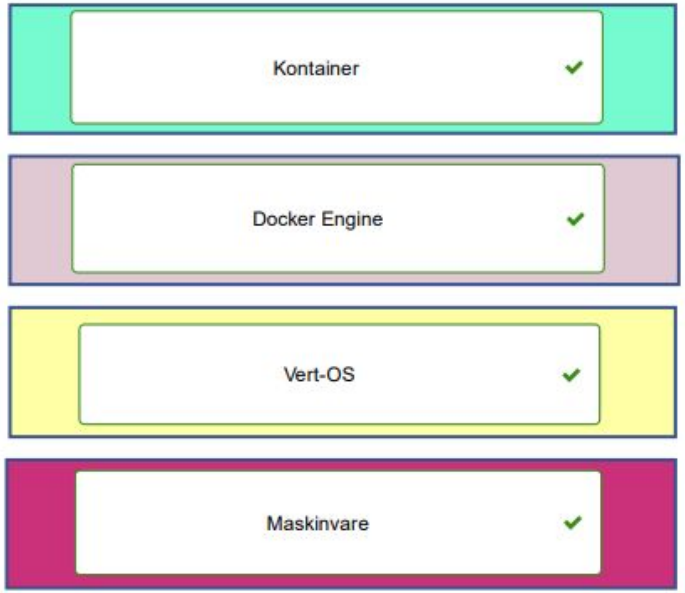
Maks poeng: 2

2.5 2.5 Kontainer

Her brukes kontainer (Docker Engine). Vis arkitekturen ved å dra de rette elementene til rett plass.
Poeng: 0,5 poeng for hver riktig, -0,5 for hver feil, 2 for alle riktig, minimum 0.

Hjelp

Vert-OS | Maskinvare | Kontainer | Docker Engine



Maks poeng: 2

Eksamen 2025

5 **OS privilegienivåer**

En prosess kjører i **hypervisormodus**. Kryss av for hvert privilegienivå om prosessen kan få tilgang til ressurser (f.eks. data og prosess).

Poeng: 0.5p for hver riktig; -0.5p for feil, 0p for ubesvart; maks 1p; minimum 0p.

For hvert privilegienivå, indiker om en bruker-prosess kan få tilgang.

	Kan få tilgang	Kan IKKE få tilgang
Nivå -1	○	○
Nivå 0	○	○

Maks poeng: 1

Eksamen 2025

5 OS privilegienivåer

En prosess kjører i **hypervisormodus**. Kryss av for hvert privilegienivå om prosessen kan få tilgang til ressurser (f.eks. data og prosess).

Poeng: 0.5p for hver riktig; -0.5p for feil, 0p for ubesvart; maks 1p; minimum 0p.

For hvert privilegienivå, indiker om en bruker-prosess kan få tilgang.

	Kan få tilgang	Kan IKKE få tilgang
Nivå -1	✔	
Nivå 0	✔	

Maks poeng: 1

Tiltrodd Beregning

Sikkerheten i et system har rotfeste i maskinvare, og man snakker ikke om det ene uten det andre.

Def: *At en kan stole på at en datamaskin oppfører seg slik den skal*

Maskinvare anses også som mer robust mot sikkerhetstrusler enn programvare.

- Vanskelig å endre, særlig over nettverk
- isolert fra resten av systemet
- mindre og enklere angrepsflate enn programvare (mindre kompleksitet)

To eksempler av tiltrodd beregning:

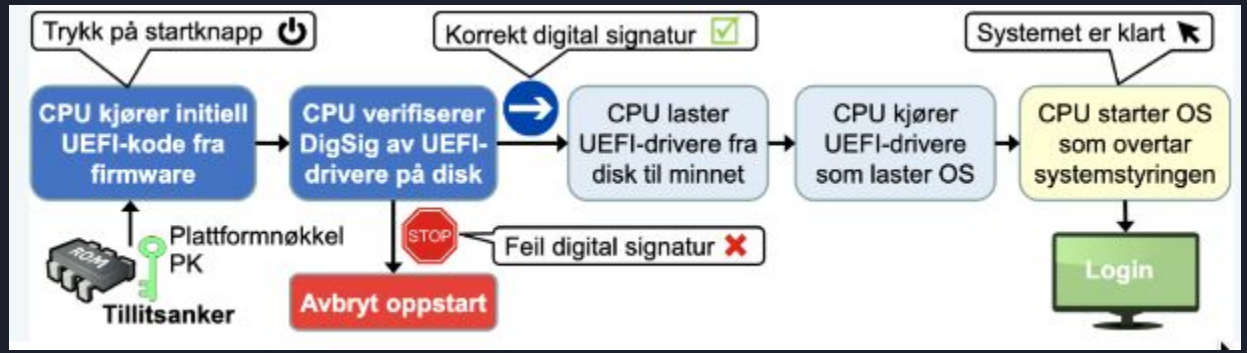
- Sikkeroppstart (secure boot) med UEFI (tidligere BIOS)
- Autentisert oppstart med TPM

Secure Boot < UEFI

Regnes som tiltrodd beregning fordi den er del av Read Only Memory (ROM)

Forhindrer innlasting av UEFI-drivere og OS-opplastere som ikke er signert med en korrekt digital signatur.

- Altså unngå at skadevare blir lastet inn under oppstart
- Dersom signaturen ikke stemmer vil den ikke starte opp



Autentisert Oppstart : TPM

- TPM (Trusted Platform Module) er en egen sikkerhetsbrikke i de fleste moderne PC-er. Den er systemets tillitsrot i maskinvare, og brukes til:

  - Målt oppstart: lagrer hash-verdier av alt som startes (integritet)

  - Attestering: signerer målingene med en unik nøkkel og beviser oppstartstilstanden overfor andre (autentisitet)

  - Forsegling av nøkler: slipper bare ut nøkler hvis oppstarten er uendret, f.eks. BitLocker-nøkkelen (konfidensialitet)

- **Sikker** oppstart blokkerer ukjent kode, mens **målt** oppstart dokumenterer den.

Eksamen 2022

2.6 **2.6 Sikker oppstart**

Tema i denne oppgaven er sikker oppstart. Velg riktig svar for hvert utsagn.

Poeng: 0,5 for hver riktig, -0,5 for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.

Finn de som passer sammen. "Bare TPM" betyr at det er sant for TPM men ikke UEFI. "Bare UEFI" betyr at det er sant for UEFI men ikke TPM. "Begge" betyr at det er sant for både TPM og UEFI, mens "Ingen" betyr at det hverken er sant for TPM eller UEFI.

	Begge	Ingen	Bare TPM	Bare UEFI
Kan brukes for å bedre sikkerhet ved oppstart	○	○	○	○
Tillitskjede basert på sertifikat i firmware	○	○	○	○
Kan brukes til å støtte autentisering	○	○	○	○
Erstatter BIOS	○	○	○	○

Maks poeng: 2

2.6 2.6 Sikker oppstart

Tema i denne oppgaven er sikker oppstart. Velg riktig svar for hvert utsagn.

Poeng: 0,5 for hver riktig, -0,5 for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.

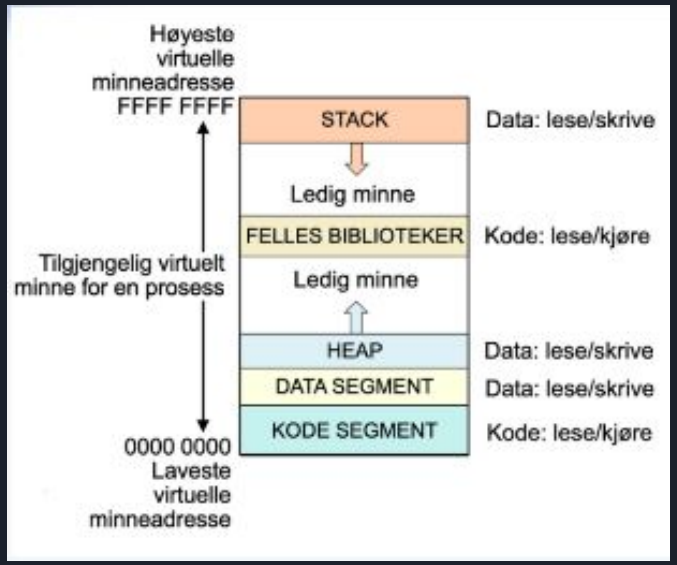
Finn de som passer sammen. "Bare TPM" betyr at det er sant for TPM men ikke UEFI. "Bare UEFI" betyr at det er sant for UEFI men ikke TPM. "Begge" betyr at det er sant for både TPM og UEFI, mens "Ingen" betyr at det hverken er sant for TPM eller UEFI.

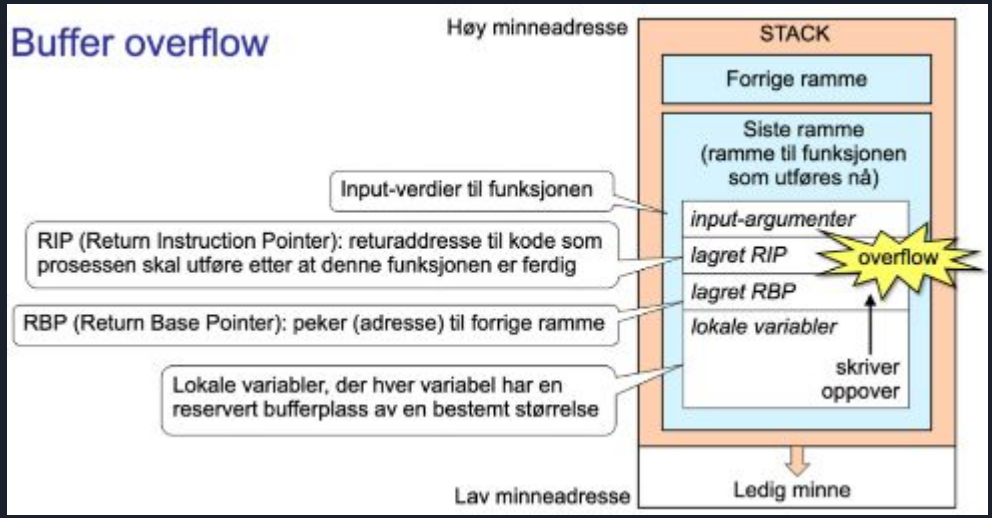
	Begge	Bare TPM	Ingen	Bare UEFI
Tillitskjede basert på sertifikat i firmware	○	○	○	○ ✔
Kan brukes til å støtte autentisering	○	○ ✔	○	○
Erstatter BIOS	○	○	○	○ ✔
Kan brukes for å bedre sikkerhet ved oppstart	○ ✔	○	○	○

Maks poeng: 2

Buffer Overflow

For mye input → overskriver returadressen → angriperen bestemmer hva programmet gjør.





Buffer Overflow

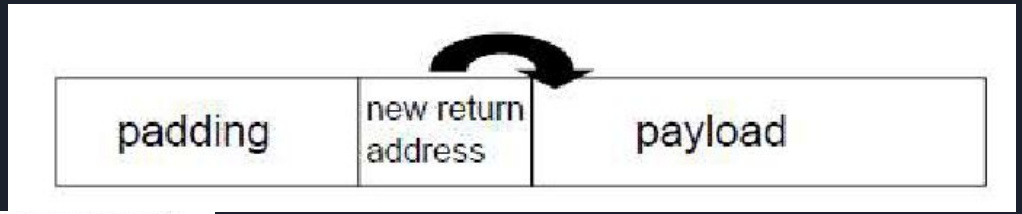
Sårbarhet i minnet (CPU utfører instruksjoner)

Man overskriver en buffer så minnet blir korrupt.

- Buffer kan være en variabel man har allokert f.eks 260 bytes

Målet til en angriper er (som regel) å overskrive Return Instruction Pointer (RIP), som forteller CPUen hvor den skal etter at en funksjon er ferdig, så kan de sette pekeren (EBP) til et annet sted i minnet.

De kan da bestemme hva som skal utføres.




```
root@kali:~# ./manymeth AAAA
```

Hvordan muligens stoppe det

No Execute: OS tillater ikke å kjøre kode på stacken / heapen

Stack Canaries: legger en “canary” (tilfeldig verdi) mellom variabler og pointer som sjekkes for endring etter en funksjon er kalt

ASLR (Address Space Layout Randomization): randomiser minneaddresser

Shadow Stack: Ha en dobbel stack (kopi) uten variable, som dermed ikke kan overskrives med buffer overflow. Programmet avbrytes ved stack-ulikhet

Eksamen 2020

5.2 **5.2 Buffer Overflow**

Angi 4 korrekte utsagn om "Buffer Overflow".
Poeng: 1 for hver korrekt, -1 for hver feil, maks 4, minimum 0.
Velg 4 alternativer:

- [ ] Buffer Overflow er når data sendes raskere enn en prosess klarer å motta.
- [ ] Buffer Overflow er en bug (feil i programvare).
- [ ] Buffer Overflow kan oppdages med fuzzing (en måte å teste programvare).
- [ ] Buffer Overflow brukes typisk som del av en exploit (skadevare).
- [ ] Buffer Overflow kan forhindres med ASLR (Address Space Layout Randomization).
- [ ] Buffer Overflow er en form for DDoS angrep.
- [ ] Buffer Overflow er når minnet er oppbrukt.
- [ ] Buffer Overflow skjer ved å skrive mere data til en variabel enn den har plass til.

Maks poeng: 4

5.2 5.2 Buffer Overflow

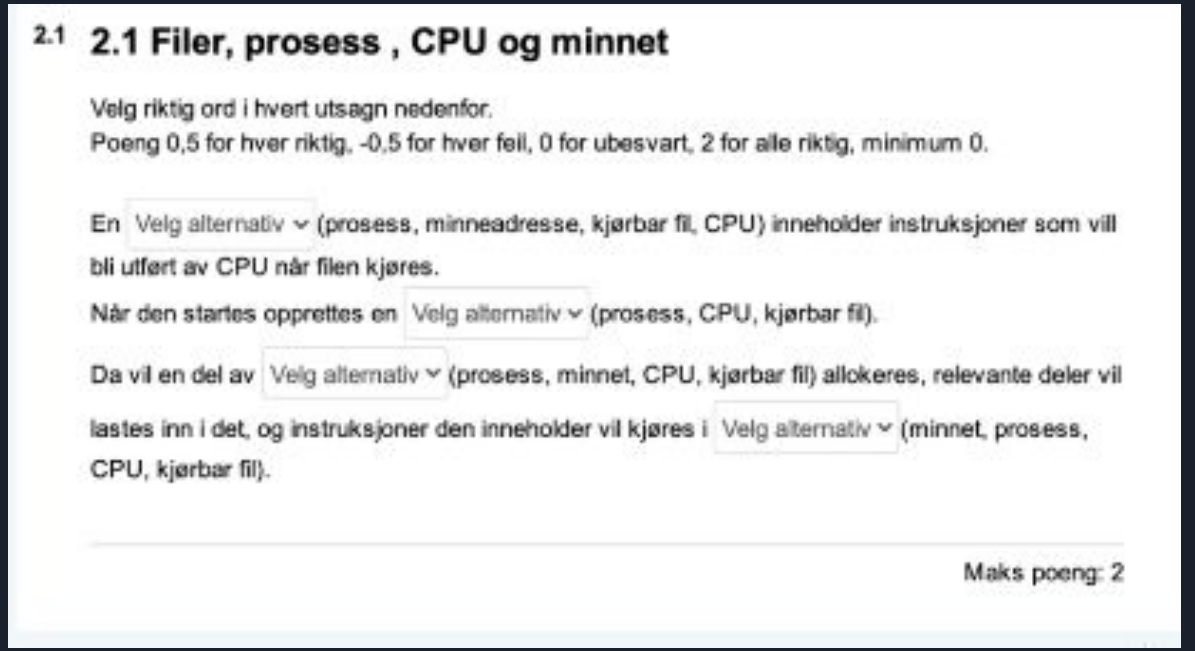
Angi 4 korrekte utsagn om "Buffer Overflow".
Poeng: 1 for hver korrekt, -1 for hver feil, maks 4, minimum 0.
Velg 4 alternativer:

- [ ] Buffer Overflow kan oppdages med fuzzing (en måte å teste programvare). ✔
- [ ] Buffer Overflow brukes typisk som del av en exploit (skadevare). ✔
- [ ] Buffer Overflow er en form for DDoS angrep.
- [ ] Buffer Overflow kan forhindres med ASLR (Address Space Layout Randomization).
- [ ] Buffer Overflow er når data sendes raskere enn en prosess klarer å motta.
- [ ] Buffer Overflow er når minnet er oppbrukt.
- [ ] Buffer Overflow skjer ved å skrive mere data til en variabel enn den har plass til. ✔
- [ ] Buffer Overflow er en bug (feil i programvare). ✔

Maks poeng: 4

Eksamen 2022

1. ?
2. ?
3. ?
4. ?



2.1 **2.1 Filer, prosess , CPU og minnet**

Velg riktig ord i hvert utsagn nedenfor.
Poeng 0,5 for hver riktig, -0,5 for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.

En Velg alternativ (prosess, minneadresse, kjørbar fil, CPU) inneholder instruksjoner som vill bli utført av CPU når filen kjøres.

Når den startes opprettes en Velg alternativ (prosess, CPU, kjørbar fil).

Da vil en del av Velg alternativ (prosess, minnet, CPU, kjørbar fil) allokeres, relevante deler vil lastes inn i det, og instruksjoner den inneholder vil kjøres i Velg alternativ (minnet, prosess, CPU, kjørbar fil).

Maks poeng: 2

2.1 2.1 Filer, prosess , CPU og minnet

Velg riktig ord i hvert utsagn nedenfor.
Poeng 0,5 for hver riktig, -0,5 for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.

En Velg alternativ (kjørbar fil, minneadresse, prosess, CPU) inneholder instruksjoner som vill bli utført av CPU når filen kjøres.
Når den startes opprettes en Velg alternativ (prosess, CPU, kjørbar fil).

Da vil en del av Velg alternativ (kjørbar fil, CPU, prosess, minnet) allokeres, relevante deler vil lastes inn i det, og instruksjoner den inneholder vil kjøres i Velg alternativ (prosess, CPU, kjørbar fil, minnet).

Maks poeng: 2

Eksamen 2022

2.2 **2.2 Prosesser og minnet**

Indiker om utsagnene nedenfor er sanne eller usanne.
Poen 0,5 for hver riktig, -0,5 for hver feil, 0 for ubesvart, 1 for begge riktig, minimum 0.

To prosesser kan **ikke** ha samme virtuelle minneadresse.
Velg ett alternativ:

- Usant
- Sant

Virtuelle minneområder fjerner buffer-overflow sårbarheten
Velg et alternativ

- Usant
- Sant

Maks poeng: 1

2.2

2.2 Prosesser og minnet

Indiker om utsagnene nedenfor er sanne eller usanne.
Poen 0,5 for hver riktig, -0,5 for hver feil, 0 for ubesvart, 1 for begge riktig, minimum 0.

To prosesser kan **ikke** ha samme virtuelle minneadresse.
Velg ett alternativ:

- ○ Usant ✔
- ○ Sant

Virtuelle minneområder fjerner buffer-overflow sårbarheten
Velg et alternativ

- ○ Usant ✔
- ○ Sant

Maks poeng: 1

Oblig 4 - Wireshark demo

Skal løse en “CTF-oppgave”. Her skal de finne et flagg ved å inspisere en PCAP fil.

- format: FLAG{.....}

En PCAP er en packet capture. La oss analysere med Wireshark.

Andre verktøy finnes sikkert, men for enkeltheten bruker jeg Wireshark.

